

Sicurezza delle Reti e dei Sistemi Informatici

Dai Framework di Controllo alle Architetture Avanzate

NECKER

23 Dicembre 2025

Indice

1	Il Framework di Sicurezza: Il Ciclo di Vita	3
2	Il Firewall: Classificazione e Tecnologie	3
2.1	Tipologie Generali	3
2.2	Packet Filtering (Stateless)	4
2.2.1	Esempio di Regole di Filtraggio (Rulebase)	4
2.3	Stateful Inspection	4
2.4	Circuit Level Gateway (Proxy)	4
2.4.1	Difese Specifiche del Circuit Level Proxy	4
2.5	Application Proxy e WAF	5
2.5.1	Vantaggi e Svantaggi	5
3	Confronto Riepilogativo delle Tecnologie	5
4	Next-Generation Firewall (NGFW)	6
5	Architetture di Rete: DMZ e Flussi	7
5.1	Logica dei Flussi di Traffico (Policy Enforcement)	7
5.2	Architettura "Composite Firewall" (Screened Subnet)	7
6	Hardening del Sistema Operativo	8
6.1	Principi e Azioni Tecniche	8
7	Sistemi di Rilevamento e Prevenzione (IDS/IPS)	9
7.1	Differenza Concettuale: IDS vs IPS	9
7.1.1	Network-Based (NIDS e NIPS)	9
7.1.2	Host-Based (HIDS e HIPS)	10
7.2	Motori di Rilevamento (Detection Engines)	10
7.2.1	1. Signature-Based (Basato su Firme)	10
7.2.2	2. Anomaly-Based (Comportamentale)	10
8	Gestione Operativa della Sicurezza (SOC & SIEM)	11
8.1	SOC (Security Operations Center)	11
8.2	SIEM (Security Information and Event Management)	11
8.3	Strutture Organizzative: SOC vs NOC vs CSIRT	12
8.4	SOC Tiers (Livelli di Analisi)	12

10 Dati e Privacy: Identificazione e Offuscamento **13**

10.1 PII (Personally Identifiable Information) 13

10.2 Steganografia (piccola digressione) 13

10.2.1 Uso Difensivo 13

9 Visione d’Insieme: Infrastruttura di Difesa Integrata **15**

1 Il Framework di Sicurezza: Il Ciclo di Vita

Il modello standard de facto per la cybersecurity è il **NIST Cybersecurity Framework**, che definisce cinque funzioni core per gestire il rischio informatico:

1. **Identify:** Inventario asset, risk assessment, governance.
2. **Protect:** Controllo accessi, crittografia, firewall.
3. **Detect:** Monitoraggio continuo e rilevamento intrusioni.
4. **Respond:** Contenimento e mitigazione dell'incidente.
5. **Recover:** Ripristino dei servizi e patching.

2 Il Firewall: Classificazione e Tecnologie

2.1 Tipologie Generali

I firewall possono essere classificati in base alla loro implementazione e posizionamento:

- **Network Firewall vs Host-based Firewall:**

- *Network Firewall:* Protegge l'intero perimetro o segmenti di rete. Include tecnologie come **Packet Filter**, **Stateful Inspection**, **Proxy** e **NGFW**.
- *Host-based Firewall:* Protegge il singolo endpoint (Server o PC). Qui rientrano il **Personal Firewall** e le pratiche di **Hardening**.

- **Hardware vs Software:**

- *Hardware (Appliance):* Dispositivi dedicati ad alte prestazioni. I moderni **NGFW** e i **Packet Filter** perimetrali sono tipicamente hardware.
- *Software:* Applicativi installati su OS generici. I **Proxy** (come Squid) e i **Personal Firewall** sono tipicamente software, anche se i Proxy moderni sono spesso integrati in appliance (soggetti a exploits del sistema operativo).

- **Perimeter vs Internal:**

- *Perimeter:* Il punto di contatto tra Internet e Intranet (o DMZ). È la collocazione standard per **Packet Filter**, **Proxy** e **NGFW**.
- *Internal:* Protezione tra dipartimenti interni o sul singolo host (Hardening).

2.2 Packet Filtering (Stateless)

Opera al livello 3 (Network) analizzando gli header IP.

- **Pro:** Molto veloce, basso overhead.
- **Contro:** Bassa sicurezza, nessuna visibilità sullo stato della connessione o sul payload.

2.2.1 Esempio di Regole di Filtraggio (Rulebase)

Un packet filter decide l'azione (Allow/Deny) basandosi su una tabella sequenziale. Esempio logico di configurazione (l'asterisco indica ANY):

Azione	Dir.	Sorgente	Destinaz.	Proto	Commento
Block	In	Bad IP List	*	*	Blocca sorgenti note malevole
Allow	Out	Internal Net	*	TCP	Permette navigazione in uscita
Allow	In	Any	Web Server	TCP 80	Accesso al sito web pubblico
Allow	In	Any	Mail Server	TCP 25	Ricezione email (SMTP)
Block	In	Any	Internal Net	*	<i>Default Deny</i> (Sicurezza base)

2.3 Stateful Inspection

Introduce la **State Table**. Il firewall ricorda il contesto non accettando per esempio **ACK** se non si ha ricevuto un pacchetto **SYN** precedentemente (es. "questo pacchetto è la risposta a una richiesta uscita 1 secondo fa").

- Opera a Livello 3 e 4.
- Gestisce connessioni dinamiche (es. FTP passivo) meglio del packet filter statico.

2.4 Circuit Level Gateway (Proxy)

Opera al livello 5 (Sessione). Interrompe la connessione diretta tra client e server, agendo come un relè per l'handshake TCP.

2.4.1 Difese Specifiche del Circuit Level Proxy

Grazie alla sua natura di intermediario della sessione, offre difese robuste contro specifici attacchi di rete:

Tipo di Attacco	Meccanismo di Prevenzione	Efficacia
TCP SYN Flood (DoS)	Il proxy completa il 3-way handshake con il client prima di contattare il server interno. Se il handshake non si conclude, il server interno non riceve nulla.	Alta
IP Spoofing	Per aprire il circuito è necessario un handshake bidirezionale completo. Un attaccante con IP spoofato non riceverà la risposta del proxy, fallendo la connessione.	Alta

TCP Session Hijacking	Il proxy divide la connessione in due segmenti con Sequence Number diversi. L'attaccante non può indovinare i numeri di sequenza interni.	Alta
Port Scanning	Topology Hiding: Il proxy nasconde gli indirizzi IP interni. Chi scansiona vede solo l'IP del proxy.	Alta

2.5 Application Proxy e WAF

Il livello massimo di sicurezza si ottiene con l'Application Level Gateway (Livello 7). A differenza dei packet filter che lasciano fluire i pacchetti, il Proxy **rompe la connessione**: agisce come un intermediario totale, terminando la connessione con il client e aprendone una nuova e separata verso il server (come Circuit Level Gateway), inoltre analizza il payload.

2.5.1 Vantaggi e Svantaggi

Questa architettura offre benefici unici ma comporta costi operativi significativi:

- **Vantaggi (Sicurezza Profonda):**
 - **Tutti i vantaggi di Circuit Level Gateway a lvl 5.**
 - **Rottura della Crittografia (WAF: Web Application Firewall):** Può decifrare il traffico HTTPS in ingresso, analizzare il payload in chiaro alla ricerca di malware, e riciclarlo verso il server interno.
 - **Livello di Sicurezza Massimo:** Grazie all'isolamento completo tra rete interna ed esterna.
- **Svantaggi (Costi e Performance):**
 - **Complessità di Setup:** Non esiste una regola "generale". Ogni applicazione (Web, Mail, FTP) richiede un proxy specifico e una configurazione dettagliata che deve seguire le evoluzioni dell'applicazione stessa.
 - **Collo di Bottiglia (Performance):** L'overhead è alto. Ogni pacchetto deve essere ricostruito fino al livello 7, analizzato, e re-incapsulato. Questo introduce latenza e richiede hardware potente.

3 Confronto Riepilogativo delle Tecnologie

Di seguito una tabella di sintesi che confronta le diverse generazioni di firewall:

Feature	Packet Filter	Stateful Inspection	Circuit Proxy	App. Proxy
Livello OSI	L3 (Network)	L3/L4 (Transport)	L5 (Session)	L7 (Application)
Focus Ispezione	Header IP Singoli	Contesto Connessione	Handshake TCP	Payload / Contenuto
Performance	Molto Veloce	Veloce	Veloce	Lenta (High Overhead)
Sicurezza	Bassa	Medio-Alta	Media	Altissima
Visibilità	Solo Header	Header + Logica Stato	Solo Handshake	Full Deep Inspection
Anonimato	Nessuno	Limitato (via NAT)	Nasconde Topologia	Totale (Full Proxy)

4 Next-Generation Firewall (NGFW)

Il NGFW rappresenta l'evoluzione dell'architettura di sicurezza perimetrale. Non si tratta di un semplice upgrade di potenza, ma di un cambiamento strutturale nel modo in cui il traffico viene processato. Mentre i firewall tradizionali (Stateful L4) basano le decisioni su "chi" (IP) e "dove" (Porta), il NGFW basa le decisioni su "cosa" (Applicazione) e "chi è realmente" (Utente), integrando prevenzione attiva delle minacce.

Il paradigma si basa su tre pilastri fondamentali:

1. Application Awareness (Layer 7 - App-ID):

- *Il Problema:* Nei firewall classici, permettere il traffico sulla porta 80 (HTTP) significava aprire la porta a tutto ciò che vi passava attraverso (tunneling, giochi, file sharing).
- *La Soluzione NGFW:* Il firewall ignora la porta standard e analizza il flusso dati per identificare la **firma dell'applicazione**. Questo permette di creare policy granulari: ad esempio, è possibile bloccare "Facebook Games" e "Facebook Chat" pur permettendo la navigazione su "Facebook Base", anche se tutto il traffico avviene sulla stessa porta TCP.
- *Micro-segmentazione:* Permette di distinguere funzioni specifiche all'interno della stessa app (es. su Dropbox: "Download = Allow", "Upload = Deny").

2. Native Integration (All-in-One & Single Pass Architecture):

- *Integrazione Modulare:* Il NGFW ingloba nativamente funzioni che storicamente richiedevano appliance separate: **IPS** (Intrusion Prevention System), Antivirus di rete, Anti-Spyware e URL Filtering.
- *Intrusion Prevention (IPS):* A differenza dell'IDS (che si limita a rilevare), l'IPS nel NGFW opera *in-line*: analizza il traffico in tempo reale e scarta attivamente i pacchetti che corrispondono a firme di exploit noti o anomalie comportamentali, bloccando l'attacco prima che entri nella rete.
- *Single Pass Architecture:* Anziché processare il pacchetto più volte in serie (una volta per il firewall, una per l'IPS, una per l'AntiVirus) creando latenza, il NGFW esegue tutte le scansioni simultaneamente in un unico passaggio in memoria. I moduli "parlano" tra loro condividendo il contesto della connessione.

3. User Identity (User-ID):

- *Superamento dell'indirizzo IP:* In reti moderne (DHCP, Wi-Fi, BYOD), l'indirizzo IP cambia continuamente e non identifica univocamente una persona.
- *Integrazione Directory:* Il NGFW si collega ai servizi di directory aziendali (es. Microsoft Active Directory, LDAP).
- *Policy basate sull'identità:* Le regole di sicurezza vengono scritte usando nomi utenti e gruppi reali. Esempio: "Consenti al gruppo 'Marketing' l'accesso ai Social Media, ma nega l'accesso al gruppo 'Stagisti'", indipendentemente da quale computer o indirizzo IP stiano usando in quel momento.

5 Architetture di Rete: DMZ e Flussi

La sicurezza perimetrale non si basa su un singolo dispositivo, ma sulla segmentazione della rete in zone a diverso livello di fiducia (*Trust Levels*). L'architettura standard de facto è la **Screened Subnet**, comunemente nota come DMZ (**Delimitarized Zone**).

5.1 Logica dei Flussi di Traffico (Policy Enforcement)

Basandosi sul principio del *Least Privilege* applicato alla rete, le regole di firewalling (mostrate negli schemi del corso) devono imporre direzionalità rigide:

- **Intranet → Internet (Outbound):** Generalmente permesso, ma filtrato. Gli host interni possono accedere all'esterno (es. HTTP/HTTPS), spesso passando attraverso un *Forward Proxy* per l'ispezione dei contenuti e il caching.
- **Internet → DMZ (Inbound Public):** Permessi solo verso servizi specifici esposti (Bastion Host). Il firewall esterno apre solo le porte strettamente necessarie (es. 80/443 per Web, 25 per SMTP) verso gli IP pubblici dei server in DMZ. Tutto il resto è *Dropped*.
- **Internet → Intranet: Severamente Vietato.** Non deve esistere alcun percorso di routing diretto che permetta a un pacchetto proveniente da Internet di raggiungere la rete interna senza intermediazione.
- **DMZ → Intranet:** Questo è il punto critico. Di default, il traffico è **bloccato**. Se un Web Server in DMZ viene compromesso, l'attaccante non deve poter "saltare" (pivot) nella rete interna. *Eccezione:* Se il Web Server deve interrogare un Database interno, si apre un "pinhole" (regola strettissima, più il passaggio è stretto più è difficile entrarci illegalmente) solo su quella porta specifica (es. TCP 3306), tra quel specifico IP sorgente e quel specifico IP destinazione.
- **DMZ → Internet:** Permessi per aggiornamenti o risposte alle richieste, ma spesso limitato per evitare che un server compromesso scarichi malware (C&C communication) o partecipi a botnet.

5.2 Architettura "Composite Firewall" (Screened Subnet)

Per ambienti *Enterprise*, non ci si affida a un solo dispositivo. Si implementa una difesa a strati (*Defense in Depth*) che costringe l'attaccante a superare molteplici ostacoli tecnologici. Facendo riferimento allo schema architetturale avanzato:

1. **Exterior Router (Packet Filtering):** È la prima linea di difesa. Esegue un filtraggio grossolano (L3/L4) per bloccare spoofing, traffico broadcast inutile e protocolli non supportati. Protegge il firewall vero e proprio da un carico eccessivo.
2. **Gateway Firewall / Bastion Host:** Posizionato tra il router esterno e la DMZ. Spesso è un **Application Proxy** o un NGFW. Qui avviene l'ispezione profonda (L7). Termina le connessioni TLS e gestisce i servizi pubblici (DNS, Mail, Web).
3. **Perimeter Network (DMZ):** La zona cuscinetto dove risiedono i server accessibili pubblicamente. Questi host sono considerati "sacrificabili" e sono sottoposti a hardening estremo.

4. **Interior Firewall:** Il componente più critico. Separa la DMZ dalla rete interna (Internal Net) e dai dipartimenti sensibili (es. Finance Group).

- **Principio della Diversificazione:** È *Best Practice* usare hw di fornitori diversi diversi per il firewall esterno e quello interno. Se un attaccante scopre una vulnerabilità *Zero-Day* sul firewall esterno, non potrà usare lo stesso exploit per superare quello interno.

6 Hardening del Sistema Operativo

Configurare i firewall è inutile se gli host stessi sono vulnerabili. L'**Hardening** è il processo sistematico di riduzione della *Superficie di Attacco* (Attack Surface) di un sistema.

6.1 Principi e Azioni Tecniche

- **Minimizzazione dei Servizi (Service Reduction):** Non basta "non usare" un servizio. Se un demone (es. FTP, Telnet, RPC) è attivo e in ascolto, è attaccabile. *Azione:* Disabilitare i servizi al boot (es. `systemctl disable`), disinstallare i binari non necessari e chiudere le porte inutilizzate. "Ciò che non c'è non può essere exploitato".
- **Account & Access Management:**
 - Eliminare o rinominare account di default (Guest, Administrator, pi).
 - Implementare il principio del *Least Privilege*: i processi web non devono girare come root, ma con utenti dedicati e limitati (es. `www-data`).
 - Enforce di password policy robuste e rotazione periodica.
- **Patch Management Proattivo:** La maggior parte degli attacchi sfrutta vulnerabilità note per le quali esiste già una patch (vulnerabilità *N-Day*). Un sistema non patchato entro 24-48h dal rilascio di un fix critico è statisticamente compromesso.
- **Logging e Audit (Non-Repudiation):** In caso di intrusione, i log sono l'unica fonte di verità. *Configurazione avanzata:* I log non devono restare solo sulla macchina locale (dove l'attaccante può cancellarli per coprire le tracce), ma devono essere inviati in tempo reale via `syslog` a un server remoto sicuro e inalterabile (Log Server / SIEM).
- **File System Integrity:** Montare le partizioni di sistema (es. `/boot`, `/usr`) in modalità *Read-Only* dove possibile. Utilizzare flag come `noexec` su cartelle temporanee (`/tmp`) per impedire l'esecuzione di script caricati dagli attaccanti.

7 Sistemi di Rilevamento e Prevenzione (IDS/IPS)

Superata la difesa perimetrale del firewall, è necessario un sistema di sorveglianza interna. Qui entrano in gioco gli IDS e gli IPS (che si suddividono in Network-Based e Host-Based).

7.1 Differenza Concettuale: IDS vs IPS

- **IDS (Intrusion Detection System):** È un sensore passivo ("Allarme antifurto").
 - Monitora il traffico o i log.
 - Se rileva un'anomalia, invia un alert all'amministratore (o al SIEM).
 - **Non blocca** il traffico. La sua operatività è "Out-of-Band" (riceve una copia del traffico tramite port mirroring/SPAN).
- **IPS (Intrusion Prevention System):** È un attuttore attivo ("Buttafuori" ma non fa prevenzione, agisce).
 - È posizionato "In-Line" (il traffico passa attraverso di esso).
 - Se rileva un attacco, lo blocca istantaneamente (dropa il pacchetto, resetta la connessione TCP).
 - Rischio: Un *falso positivo* blocca traffico legittimo (DoS auto-inflicto).

7.1.1 Network-Based (NIDS e NIPS)

Questi strumenti analizzano i pacchetti di rete "in transito" (on-the-wire), agendo come un filtro tra i dispositivi.

- **NIDS (Network Intrusion Detection System):**
 - **Cos'è:** È un IDS posizionato sulla rete. È l'equivalente di una telecamera di sorveglianza a circuito chiuso.
 - **Come funziona:** L'interfaccia di rete è in "Promiscuous Mode" (sniffing). Riceve una *copia* del traffico (tramite Port Mirroring/SPAN sullo switch) senza interferire col flusso dati.
 - **Differenza con l'IPS:** Se il NIDS vede un attacco, lancia un allarme, ma i pacchetti malevoli arrivano comunque a destinazione perché il NIDS è posizionato "di lato" (Out-of-Band).
- **NIPS (Network Intrusion Prevention System):**
 - **Cos'è:** È un IPS posizionato sulla rete. È l'equivalente di un posto di blocco doganale armato.
 - **Come funziona:** È posizionato *In-Line* (in serie sul cavo). Il traffico *deve* passare attraverso il NIPS per procedere.
 - **Differenza con l'IDS:** Se il NIPS vede un attacco, scarta il pacchetto (*Drop*) istantaneamente. Il pacchetto malevolo non raggiungerà mai la destinazione.

7.1.2 Host-Based (HIDS e HIPS)

Software (Agent) installati direttamente sul singolo server o endpoint.

- **HIDS/HIPS:** Monitorano ciò che accade *dentro* la macchina: modifiche ai file di sistema (File Integrity Monitoring), log di Windows/Linux, accessi alla memoria.
- **Vantaggio sui Network-based:** Vedono il traffico *dopo* che è stato decifrato (es. HTTPS terminato) e possono rilevare attacchi locali che non passano dalla rete (es. attacchi tramite chiavetta USB).

7.2 Motori di Rilevamento (Detection Engines)

Come fa il sistema a capire se sta avvenendo un attacco?

7.2.1 1. Signature-Based (Basato su Firme)

Confronta il traffico con un database di "impronte" di attacchi noti (simile all'antivirus classico).

- **Pro:** Molto veloce, basso tasso di falsi positivi.
- **Contro:** Cieco contro attacchi *Zero-Day* (sconosciuti) o malware polimorfo.

7.2.2 2. Anomaly-Based (Comportamentale)

Crea un profilo (*Baseline*) del comportamento "normale" dell'utente o della rete e segnala le deviazioni. (*Rif. Slide "Profiling Information"*) Il sistema apprende abitudini monitorando parametri come:

- **Activity & Time:** Login alle 3:00 AM da un utente che lavora dalle 9 alle 18.
- **Data Volume:** Un server che invia 10GB di dati verso un IP esterno sconosciuto (sospetta esfiltrazione).
- **Application Usage:** Uso di PowerShell da parte di una segretaria.
- **Location:** Accesso simultaneo da Milano e New York (Impossible Travel).
- **Pro:** Rileva Zero-Day e abusi di credenziali.
- **Contro:** Alto tasso di falsi positivi (basta cambiare abitudine lavorativa per generare un alert).

8 Gestione Operativa della Sicurezza (SOC & SIEM)

Per garantire la sicurezza in un'azienda moderna non bastano i software, serve una struttura organizzativa dedicata.

8.1 SOC (Security Operations Center)

Il SOC è l'unità centralizzata (fisica o virtuale) responsabile del monitoraggio, dell'analisi e della risposta agli incidenti di sicurezza su base continuativa (spesso 24/7). Mentre il firewall è uno strumento, il SOC è una ****capacità operativa**** composta da tre pilastri indispensabili:

1. **Persone (People):** Gli analisti di sicurezza (divisi in Tier 1, 2, 3) che interpretano gli allarmi.
2. **Processi (Processes):** Le procedure standard (*Playbooks*) che dettano come reagire a un attacco (es. "Cosa fare se rileviamo un ransomware?").
3. **Tecnologia (Technology):** Gli strumenti software che raccolgono dati e fermano le minacce (SIEM, Firewall, EDR).

Obiettivo del SOC: Minimizzare il tempo che intercorre tra l'inizio di un'intrusione e la sua neutralizzazione (*Time to Detect* e *Time to Respond*).

8.2 SIEM (Security Information and Event Management)

Se il SOC è il team di sorveglianza, il SIEM è il loro "pannello di controllo". Poiché un'azienda ha decine di strumenti di sicurezza eterogenei (Firewall, Antivirus, Proxy, IDS, VPN Concentrators), per un essere umano è impossibile controllarli uno a uno in tempo reale.

Il SIEM risolve questo problema tramite tre fasi:

- **Aggregazione:** Centralizza i log provenienti da tutte le fonti (Network devices, Server, Applicazioni, Database) in un unico repository.
- **Normalizzazione:** Traduce log di formati diversi (es. Syslog di Cisco, EventLog di Windows, JSON di AWS) in un formato standard comune leggibile e interrogabile.
- **Correlazione (Intelligenza):** Analizza i dati per collegare eventi che, presi singolarmente, sembrano innocui, ma insieme indicano un attacco.

Esempio di Correlazione:

- Evento A: "5 login falliti sul Firewall" (Tentativo Brute Force).
- Evento B: "1 login successo sulla VPN subito dopo" (Accesso riuscito).
- Evento C: "Creazione account admin sul Domain Controller".
- **Risultato SIEM:** Generazione di un **High Severity Alert** per furto di credenziali ed escalation di privilegi.

8.3 Strutture Organizzative: SOC vs NOC vs CSIRT

Entità	Focus Principale	Obiettivo
NOC (Network Operations Center)	Disponibilità e Performance. Si preoccupa se la rete è lenta, se un link è caduto o se c'è latenza.	Garantire l'SLA di uptime e la qualità del servizio (QoS).
SOC (Security Operations Center)	Sicurezza e Minacce. Si preoccupa se i dati sono a rischio, se c'è un'intrusione o un malware.	Rilevare, analizzare e rispondere agli incidenti di sicurezza.
CSIRT / CERT (Computer Emergency Response Team)	Risposta all'Incidente. Team specializzato (spesso parte del SOC o esterno) che interviene "durante l'incendio".	Forensics, contenimento dell'incidente critico, ripristino.

8.4 SOC Tiers (Livelli di Analisi)

Il personale del SOC è tipicamente diviso in tre livelli gerarchici:

1. **Tier 1 (Triage Analyst):** Monitora la dashboard del SIEM. Filtra i falsi positivi, gestisce gli alert di base e scala quelli critici. (Skill base, ormai l'AI sta sostituendo l'uomo).
2. **Tier 2 (Incident Responder):** Analizza gli incidenti scalati dal Tier 1. Indaga la causa scatenante (*Root Cause Analysis*), valuta l'impatto e propone azioni di rimedio.
3. **Tier 3 (Threat Hunter / Expert):** Esperti senior. Non aspettano gli alert, ma cercano attivamente minacce nascoste nella rete (*Threat Hunting*). Si occupano di Malware Analysis e Digital Forensics avanzata. (nel mondo mancano moltissime figure in grado di ricoprire questo ruolo)

10 Dati e Privacy: Identificazione e Offuscamento

10.1 PII (Personally Identifiable Information)

Nel monitoraggio (IDS/SIEM) vengono trattati dati sensibili. È fondamentale distinguere:

- **PII (Dati Identificativi Diretti):** Dati che identificano univocamente una persona (Nome, Codice Fiscale, Numero Carta di Credito, Indirizzo Email, Dati Biometrici). Richiedono la massima protezione (GDPR).
- **Non-PII / Linked Data:** Dati che da soli non identificano una persona (es. "Genere: Maschio", "Città: Milano", "Libri letti"), ma se combinati (Data Linkage) possono portare alla *Re-identificazione* del soggetto (tecnica di deanonymization).

10.2 Steganografia (piccola digressione)

Mentre la **Crittografia** rende il messaggio illeggibile (nasconde il significato), la **Steganografia** rende il messaggio **invisibile** (nasconde l'esistenza stessa della comunicazione).

- **Tecnica Classica (LSB - Least Significant Bit):** Si modificano i bit meno significativi dei pixel di un'immagine. *Esempio:* In una foto RGB a 24 bit, modificare l'ultimo bit di ogni byte di colore cambia la sfumatura in modo impercettibile all'occhio umano, ma permette di nascondere un file di testo o un malware all'interno dell'immagine.
- **Uso in Cybersecurity:**
 - *Offensivo:* Malware che scaricano configurazioni nascoste dentro loghi di siti web legittimi (per evadere l'IPS).
 - *Difensivo:* Watermarking digitale per tracciare la proprietà dei documenti (DLP - Data Loss Prevention).

10.2.1 Uso Difensivo

1. **Digital Fingerprinting (Traitor Tracing):** È l'applicazione più diffusa in ambito Enterprise e militare.
 - *Scenario:* Un'azienda invia un documento riservato a 50 dipendenti.
 - *Tecnica:* Viene generata una copia diversa per ogni dipendente, inserendo tramite steganografia un ID univoco invisibile (es. cambiando impercettibilmente la spaziatura tra le parole o i bit meno significativi di un logo).
 - *Difesa:* Se il documento viene fotografato e pubblicato su un giornale (*Data Leak*), l'azienda analizza l'immagine, estrae l'ID nascosto e identifica esattamente **chi** ha fatto uscire il documento (Non-Repudiation).
2. **Fragile Watermarking (Verifica di Integrità):** Serve a capire se un file è stato manomesso (Tampering).
 - *Tecnica:* Si nasconde un watermark "fragile" all'interno di un'immagine o di un audio (es. una prova forense o una registrazione di una telecamera di sicurezza).
 - *Difesa:* Questo watermark è progettato per "rompersi" se anche un solo bit del file viene modificato. Se in tribunale si analizza il file e il watermark non è leggibile, significa che la prova è stata alterata e non è più autentica.

3. **Honeytokens (Trappole):** Si usa la steganografia per nascondere "esche" all'interno della rete.

- *Difesa:* Si nascondono credenziali finte (fake password) dentro file apparentemente importanti ma nascosti steganograficamente. Nessun utente legittimo le userebbe mai. Se il SIEM rileva un tentativo di login con quelle credenziali, significa che un attaccante ha scansionato a fondo i file ed è caduto nella trappola.

9 Visione d'Insieme: Infrastruttura di Difesa Integrata

